COMPTIA SECURITY+ SY0-701 | DOMAIN 4 · SECURITY OPERATIONS (28%)

Security+ 4.3 · Penetration Testing

Mestre CyberSec · **Lesson 4.3 — Penetration Testing** (6:21) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: Pentest: simula ataque pra EXPLODIR falha real e mostrar o impacto. ROE (rules of engagement) define: alvo, janela, técnica, não-quebrar. Responsible disclosure: reporta pro vendor ANTES de publicar. Tipo: white/black/grey box.

💡 Key Exam Highlights & Critical Concepts

- ROE (rules of engagement): o que PODE e o que NÃO PODE fazer no pentest
- White-box: com acesso total; black-box: sem nada
- Responsible disclosure: reporta pro vendor antes de publicar

🎯 Exam Tips & Typical CompTIA Scenarios

- 'agreement on what the pentester can and cannot do'=ROE

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 4.3 — Penetration Testing)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Penetration Testing (Pentest)

A simulated cyberattack against systems to identify and exploit vulnerabilities, demonstrating real business impact before a real attacker does.

⚠️ ***Exam Trap:*** *Diferença crucial: pentest explora vulnerabilidades para provar impacto; varredura de vulnerabilidade apenas as identifica. Se a questão fala em 'simulated attack' ou 'exploit', é pentest.*

• Rules of Engagement (ROE)

A formal document that defines the scope, timing, allowed techniques, and boundaries of a penetration test, including what the tester may and may not do.

⚠️ ***Exam Trap:*** *Gatilho clássico: 'agreement on what the pentester can and cannot do' = ROE. Não confunda com contrato de confidencialidade ou autorização simples.*

• White-box Testing

A penetration test where the tester has full knowledge of the target, including source code, network diagrams, and credentials.

⚠️ ***Exam Trap:*** *Se a questão menciona 'full access', 'source code', 'credentials' ou 'inside knowledge', é white-box. Maior cobertura, menor tempo de reconhecimento.*

• Black-box Testing

A penetration test where the tester has no prior knowledge of the target and simulates an external attacker with zero access.

⚠️ ***Exam Trap:*** *Se a questão diz 'no knowledge', 'zero access' ou 'simulates external attacker', é black-box. Mais realista, porém mais demorado.*

• Gray-box Testing

A penetration test where the tester has partial knowledge of the target, such as some credentials or limited documentation, combining insider and outsider perspectives.

⚠️ ***Exam Trap:*** *Se a questão menciona 'partial knowledge' ou 'some credentials', é gray-box. É o meio-termo entre white e black.*

- **Responsible Disclosure**

The practice of reporting a discovered vulnerability privately to the vendor and allowing time for a patch before publicly disclosing it.

⚠️ ***Exam Trap:*** *Gatilho: 'reporta pro vendor ANTES de publicar'. Se a questão pergunta o que fazer após achar uma vulnerabilidade, escolha responsible disclosure, não publicação imediata.*

- **Bug Bounty**

A program that offers financial rewards or recognition to security researchers who responsibly report qualifying vulnerabilities in an organization's systems.

⚠️ ***Exam Trap:*** *Não é o mesmo que pentest contratado. Bug bounty é aberto a pesquisadores externos e geralmente recompensa apenas vulnerabilidades válidas e dentro do escopo.*

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A security consultant has been hired by a mid-sized e-commerce company to perform a security assessment. Before the engagement begins, the consultant requests a formal document that defines the scope of network ranges in scope, the testing window (business hours only), approved exploitation techniques, and emergency contact procedures. Which document is the consultant requesting?

A) Statement of Work (SOW)

B) Rules of Engagement (ROE)

C) Non-Disclosure Agreement (NDA)

D) Service Level Agreement (SLA)

QUESTION 2 · EXAM SCENARIO

An organization wants to simulate an external attacker's perspective against their public website. They provide the testing team with NO documentation, NO network diagrams, NO source code, and NO prior credentials. The team must perform reconnaissance from scratch, just as a real adversary would. Which type of penetration test is being described?

A) White-box testing

B) Gray-box testing

C) Black-box testing

D) Crystal-box testing

QUESTION 3 · EXAM SCENARIO

A security engineer is conducting an internal penetration test and is given a standard domain user account, a partial network diagram showing only the DMZ segment, and access to internal documentation about the company's approved applications. The goal is to determine what an insider or compromised employee account could access. Which testing methodology does this scenario represent?

A) Black-box testing

B) Double-blind testing

C) Gray-box testing

D) Tiger team assessment

QUESTION 4 · EXAM SCENARIO

A penetration tester discovers a critical authentication bypass vulnerability in a popular commercial web application during an authorized engagement. After verifying the finding, the tester drafts a detailed report and follows a 60-day private disclosure timeline with the vendor before any public disclosure can occur. Which security principle is being applied here?

A) Full disclosure

B) Zero-day exploitation

C) Responsible disclosure

D) Coordinated denial of service

QUESTION 5 · EXAM SCENARIO

A startup company cannot afford to hire a full red team but wants continuous external security testing. They establish a program through a public platform where independent researchers can submit vulnerabilities found in their public-facing assets. Researchers receive monetary compensation based on the severity of their findings, and the company maintains a public leaderboard of top contributors. Which program has the company implemented?

A) Vulnerability management program

B) Bug bounty program

C) Penetration testing engagement

D) Security audit program

QUESTION 6 · EXAM SCENARIO

A CISO is comparing two security testing approaches for an upcoming annual assessment. Approach A uses automated tools to scan systems for missing patches and misconfigurations without exploiting any findings, generating a report of weaknesses. Approach B involves skilled testers actively attacking infrastructure to demonstrate how an attacker could chain vulnerabilities together to compromise critical assets. Which statement BEST describes the difference between these two approaches?

A) Approach A is a penetration test, and Approach B is a vulnerability scan

B) Approach A is a vulnerability scan, and Approach B is a penetration test

C) Both approaches are considered penetration tests

D) Both approaches are vulnerability scans

QUESTION 7 · EXAM SCENARIO

A security researcher discovers a buffer overflow in a network appliance's management web GUI. She follows the vendor's published security policy, which states that researchers must send the technical details via PGP-encrypted email to security@vendor.tld and must not publicly disclose the issue until a patch is released OR 90 days have passed, whichever comes first. Which disclosure model is the vendor enforcing?

A) Full immediate public disclosure

B) No disclosure policy

C) Coordinated/responsible disclosure with a deadline

D) Vulnerability auction model

QUESTION 8 · EXAM SCENARIO

A financial institution is hiring a penetration testing firm and wants the assessment to be as thorough as possible. They provide the testers with complete source code of their flagship product, architecture diagrams, credentials for a domain administrator account, and detailed network topology documentation. The testers should validate security from the perspective of a fully informed insider with complete access. Which testing methodology best fits this requirement?

A) Black-box testing

B) External-only testing

C) White-box testing

D) Targeted testing

QUESTION 9 · EXAM SCENARIO

A penetration tester executes a successful SQL injection attack that exfiltrates an entire customer database from a target web application. The tester immediately stops further exploitation, captures all logs and screenshots, and prepares a formal report documenting the attack chain, business impact, and recommended remediation. The client had authorized testing in writing beforehand. Which critical element did the tester demonstrate by stopping immediately after data exfiltration?

A) Exceeding the scope of the engagement

B) Adhering to the Rules of Engagement regarding 'do no harm' and evidence preservation

C) Conducting an unauthorized attack

D) Violating the responsible disclosure timeline

QUESTION 10 · EXAM SCENARIO

An organization wants to conduct a penetration test of their production environment but is concerned about service disruption. They define in the engagement rules that Denial-of-Service (DoS) attacks are strictly prohibited, social engineering of employees is not authorized, and any findings that could impact system availability must be coordinated with the operations team before exploitation. Which document contains these restrictions?

A) The risk register

B) The incident response plan

C) The Rules of Engagement (ROE)

D) The business continuity plan

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option B — Rules of Engagement (ROE)

The Rules of Engagement (ROE) is the formal document that defines exactly how a penetration test will be conducted, including scope boundaries, approved techniques, testing windows, communication channels, and emergency escalation procedures. The SOW defines deliverables and project scope at a higher level, the NDA protects confidential information, and the SLA defines service performance metrics. The ROE is specifically the operational contract that governs tester behavior during the engagement.

Question 2: Option C — Black-box testing

Black-box testing simulates an external attacker with no prior knowledge of the target environment. The testing team must perform reconnaissance, enumeration, and exploitation from scratch, mirroring a real-world adversary's approach. White-box testing provides full knowledge (source code, network diagrams, credentials), while gray-box testing provides partial knowledge (typically a user-level account). Crystal-box is not a standard pentest classification.

Question 3: Option C — Gray-box testing

Gray-box testing provides the tester with partial knowledge of the environment — typically simulating an insider threat or an attacker who has compromised a low-privilege account. In this scenario, the tester has some documentation and a basic user account, which is the hallmark of gray-box testing. Black-box testing would provide no internal data, and double-blind testing would prevent even the IT staff from knowing a test is occurring. 'Tiger team' is a generic term for an attacking team, not a specific methodology.

Question 4: Option C — Responsible disclosure

Responsible disclosure is the practice of privately reporting vulnerabilities to the vendor/developer first, allowing them time to develop and release a patch before any public disclosure. This balances security research transparency with protecting users from active exploitation. Full disclosure would publish the vulnerability immediately, zero-day exploitation involves using unknown vulnerabilities maliciously, and coordinated DoS is unrelated to vulnerability disclosure.

Question 5: Option B — Bug bounty program

A bug bounty program is a crowdsourced security testing initiative that invites independent researchers to find and report vulnerabilities in exchange for monetary rewards based on severity. These programs are hosted on platforms like HackerOne or Bugcrowd. A traditional penetration testing engagement is contracted with a specific team for a fixed scope, a vulnerability management program tracks and remediates identified weaknesses internally, and a security audit typically focuses on compliance rather than exploitation.

Question 6: Option B — Approach A is a vulnerability scan, and Approach B is a penetration test

Approach A describes a vulnerability scan — automated identification of weaknesses without active exploitation. Approach B describes a penetration test — skilled testers actively exploit vulnerabilities to demonstrate real-world impact and attack chains. The key distinction is that penetration tests involve manual exploitation to show actual business risk, while vulnerability scans simply identify and report potential issues. Both are valuable but serve different purposes.

Question 7: Option C — Coordinated/responsible disclosure with a deadline

This is a coordinated (responsible) disclosure model with a hard deadline. The vendor specifies a private reporting channel (PGP-encrypted email) and a defined disclosure window (patch release OR 90 days), which protects users while still incentivizing timely remediation. Full immediate disclosure would publish details right away, a no-disclosure policy would suppress findings indefinitely, and vulnerability auctions would sell the flaw to the highest bidder.

Question 8: Option C — White-box testing

White-box testing (also called clear-box or full-knowledge testing) provides the testing team with complete information about the target environment, including source code, credentials, network diagrams, and architectural documentation. This methodology enables the most thorough assessment and is typically the most cost-effective since testers don't waste time on reconnaissance. Black-box testing provides no internal information, external-only testing restricts scope to internet-facing assets, and targeted testing is not a standard classification.

Question 9: Option B — Adhering to the Rules of Engagement regarding 'do no harm' and evidence preservation

By stopping immediately after demonstrating impact (data exfiltration) and preserving evidence (logs and screenshots) for the report, the tester is adhering to the ROE principle of 'do no harm' — proving the vulnerability's impact without causing further damage. This is professional pentest behavior that demonstrates risk without amplifying it. Exceeding

scope or conducting unauthorized attacks would be unethical and potentially illegal, and the disclosure timeline applies to vendors and external researchers, not the tested client.

Question 10: Option C — The Rules of Engagement (ROE)

The Rules of Engagement explicitly defines what testers are permitted and prohibited from doing during the assessment. Prohibiting DoS attacks, restricting social engineering, and requiring coordination for availability-impacting tests are all classic ROE restrictions. The risk register tracks organizational risks, the incident response plan handles active security incidents, and the business continuity plan addresses disaster recovery — none of these define pentest operational constraints.